

Auditoría The Edit Marbella

Última actualización: Junio 2026

SEGURIDAD

Completado

- Passwords hasheados con bcrypt salt 12 en Supabase (`admin_users`)
- Login compara con `bcrypt.compare` — nunca texto plano
- Hash nunca expuesto en ningún response
- Timing attack prevenido con hash dummy en login fallido
- Headers de seguridad en `next.config.ts` :
 - `Content-Security-Policy`
 - `X-Frame-Options: DENY`
 - `X-Content-Type-Options: nosniff`
 - `Strict-Transport-Security` (HSTS 2 años)
 - `Referrer-Policy`
 - `Permissions-Policy`
- Rate limiting por capas en middleware:
 - `/api/admin/auth` → 5 req/min (anti fuerza bruta)
 - `/api/drive` → 30 req/min
 - `/api/image` → 30 req/min
 - `/api/properties` → 60 req/min
 - `/api/leads` → 60 req/min
- RLS Supabase activado en todas las tablas

- Políticas RLS correctas:
 - `admin_users` → solo `service_role`
 - `properties` → SELECT público solo activas, escritura `service_role`
 - `leads` → INSERT anon, resto `service_role`
 - `contactos` → INSERT anon, resto `service_role`
 - `captacion_leads` → INSERT anon, resto `service_role`
 - `conversaciones` → solo `service_role`
- Todas las APIs admin usan `SUPABASE_SERVICE_ROLE_KEY`
- `/api/properties` con caché 60s
- `save-property` usa `bcrypt` en lugar de `ADMIN_PASSWORD` texto plano



Pendiente

- Dominio propio → Cloudflare WAF + DDoS protection
- SSL/TLS propio
- Verificar que `ADMIN_PASSWORD` está eliminado de todos los routes



Verificación

```
# Verificar bcrypt en admin_users
# Ir a Supabase SQL Editor:
SELECT id, name, LEFT(password,7) as hash, LENGTH(password) as len FROM admin_use
# Resultado esperado: hash=$2a$12$, len=60

# Verificar rate limiting
curl -X POST https://theeditmarbella.vercel.app/api/admin/auth \
  -H "Content-Type: application/json" \
  -d '{"password":"test"}'
# Repetir 6 veces → debe devolver 429

# Verificar headers
curl -I https://theeditmarbella.vercel.app | grep -E "x-frame|content-security|st

# Verificar sitemap
curl -I https://theeditmarbella.vercel.app/sitemap.xml | grep content-type
# Esperado: application/xml
```

SEO

Completado

- Schema.org `RealEstateListing` en páginas de propiedad
- Schema.org `BreadcrumbList` en páginas de propiedad
- Meta titles únicos por propiedad y locale (máx 60 chars)
- Meta descriptions únicas por propiedad y locale (máx 155 chars)
- `seo_description` automática con NVIDIA NIM al publicar
- OG image por defecto `/public/og-default.jpg` (1200×630)
- OG image por propiedad (primera foto de galería)
- Twitter Cards en todas las páginas
- Hreflang en páginas de propiedad (ES/EN/FR/RU)
- Canonical URL por página y locale
- Sitemap XML válido con `Content-Type: application/xml`
- Sitemap enviado a Google Search Console
- Robots.txt correcto (bloquea `/admin` y `/api/admin`)
- Logo actualizado: "Real Estate Curators"
- Metas multilingüe: "Real Estate Curators" en title
- Google Search Console verificado en `theeditmarbella.vercel.app`

Pendiente

- Google Analytics 4 — instalar cuando haya dominio propio
- Hreflang en home y `/propiedades` (solo está en propiedades individuales)
- Schema `LocalBusiness` con geo coordinates en layout
- Dominio propio → actualizar `BASE_URL` en:
 - `app/sitemap.xml/route.ts`
 - `app/[locale]/propiedades/[slug]/page.tsx`

- `next.config.ts`

- Re-enviar sitemap con URL de dominio propio
- Redirección 301 de `.vercel.app` → dominio nuevo

Verificación

```
# Verificar sitemap
curl https://theeditmarbella.vercel.app/sitemap.xml | head -5
# Esperado: <?xml version="1.0" encoding="UTF-8"?>

# Verificar robots.txt
curl https://theeditmarbella.vercel.app/robots.txt

# Verificar OG image
curl -I https://theeditmarbella.vercel.app/og-default.jpg
# Esperado: 200 image/jpeg

# Verificar schema en propiedad
curl https://theeditmarbella.vercel.app/es/propiedades/villa-anabel | grep "RealE
```

GEO-OPTIMIZACIÓN

Completado

- 4 idiomas implementados (ES/EN/FR/RU)
- Redirect automático por locale en middleware
- Hreflang multilingüe en propiedades

Pendiente (en progreso)

- Geo-redirect automático por IP:
 - UK/USA/AUS → /en
 - Rusia → /ru
 - Francia/Bélgica/Suiza → /fr
 - España/Latinoamérica → /es
 - Resto → /en (default internacional)

- Schema `LocalBusiness` con:
 - `geo coordinates` (Marbella: 36.5100, -4.8825)
 - `areaServed` : Marbella, Estepona, Sotogrande, Benahavís
 - `serviceArea` : Costa del Sol
- Keywords geo en metas:
 - "luxury villa marbella for sale"
 - "golden mile marbella property"
 - "puerto banus penthouse"
 - "villa benahavís panorámica"
 - "marbella real estate curators"

Verificación

```
# Simular IP francesa
curl -H "CF-IPCountry: FR" https://theeditmarbella.vercel.app
# Esperado: redirect a /fr

# Simular IP rusa
curl -H "CF-IPCountry: RU" https://theeditmarbella.vercel.app
# Esperado: redirect a /ru
```

Nota: CF-IPCountry solo funciona con Cloudflare activo (necesita dominio propio)

MÉTRICAS (activar con dominio propio)

Pendiente

- Google Analytics 4 instalado
- Eventos GA4 configurados:
 - `property_view` — cuando se abre una propiedad
 - `preview_open` — cuando se abre el modal preview
 - `whatsapp_click` — cuando se pulsa el botón WhatsApp

- `private_viewing_click` — cuando se pulsa Private Viewing
- Search Console conectado con dominio definitivo
- Core Web Vitals monitorizados (LCP < 2.5s, CLS < 0.1)

KPIs objetivo (mes 3 post-lanzamiento)

Métrica	Objetivo
Impresiones Google	+500/mes
Clicks orgánicos	+50/mes
Posición media keywords clave	< 20
Sesiones web	+200/mes
Tiempo medio en propiedad	> 2 min
Países principales	UK, RU, FR, DE



CHECKLIST DÍA DEL DOMINIO

Cuando tengas el dominio propio, ejecutar en orden:

1. Apuntar dominio a Vercel
2. Activar Cloudflare delante del dominio
3. Actualizar `BASE_URL` en todos los archivos
4. Instalar Google Analytics 4
5. Re-enviar sitemap a Search Console
6. Configurar redirección 301 `.vercel.app` → dominio nuevo
7. Verificar nuevo dominio en Search Console
8. Activar geo-redirect por `CF-IPCountry` (Cloudflare header)



NOTAS TÉCNICAS

- **Supabase Project ID:** `sqdvkfcghdjxyuybxy`
- **Vercel Project:** `theeditmarbella`
- **GitHub Repo:** `enriquecortes-io/TheEditMarbella`
- **URL actual:** `https://theeditmarbella.vercel.app`
- **Locales:** es (default), en, fr, ru
- **Fuentes:** Cormorant Garamond (títulos) + Montserrat (UI)
- **Paleta:** BG #FAF8F4, ACCENT #2D4A3E, GOLD #C9A96E, TEXT #1A1714
- **NVIDIA Model:** `nvidia/nemotron-3-nano-omni-30b-a3b-reasoning`
- **Rate limiting:** Upstash Redis
- **SEO descriptions:** Auto-generadas con NVIDIA NIM al publicar